

Fase 1: Configurazione dell'Ambiente e Requisiti rete

Prima di procedere all'installazione è fondamentale garantire l'isolamento e l'accesso controllato della macchina virtuale alla rete internet per lo scaricamento dei pacchetti necessari.

1. Configurazione dell'Hypervisor (Virtualbox)

- Azione: Modifica delle impostazioni di rete della VM kali linux
- Impostazione: Configurare la Scheda 1 in modalità Scheda con bridge selezionando l'interfaccia fisica attiva dell'host (es. Intel(R) Dual Band Wireless- AC 8260)
- Verifica: Avviare la macchina, aprire il browser interno e navigare su un dominio esterno (es. [google.com](https://www.google.com)) per confermare la corretta risoluzione DNS e il routing.

Fase 2: Installazione dei Servizi e della Web Application

L'architettura dell'applicazione richiede lo stack LAMP standard (Linux, Apache, MySQL/MariaDB, PHP)

2. Download e Privilegi del File System

I comandi devono essere eseguiti con privilegi amministrativi elevati (sudo su) :

```
bash
```

```
# Spostarsi nella root directory del Web Server Apache
cd /var/www/html
```

```
# Clonare il repository ufficiale di DVWA
git clone https://github.com
```

```
# Assegnare i permessi massimi di lettura/scrittura/esecuzione alla cartella (necessario per
laboratori di Upload/Inclusion)
chmod -R 777 DVWA/
```

3. Configurazione dell'Applicazione

Configurazione dei parametri di interfacciamento al Database

bash

```
cd DVWA/config  
cp config.inc.php.dist config.inc.php  
nano config.inc.php
```

All interno del file valorizzare l'array delle variabili come segue per matchare i parametri di sicurezza di MariaDB:

```
- $_DVWA['db_database'] = 'dvwa';  
  
- $_DVWA['db_user'] = 'kali';  
  
- $_DVWA['db_password'] = 'kali';  
  
- $_DVWA['db_port'] = '3306';
```

4. Inizializzazione del Database MySQL/MariaDB

Avvio del servizio DBMS e hardening per DVWA

bash

```
# Avviare il demone mysql  
service mysql start
```

```
# Accedere alla CLI di MariaDB (password standard di root su Kali: "kali")  
mysql -u root -p
```

All interno della console MariaDB eseguire le seguenti query SQL per creare l'utente dedicato identificato nel file di configurazione:

sql

```
CREATE USER 'kali'@'127.0.0.1' IDENTIFIED BY 'kali';  
GRANT ALL PRIVILEGES ON dvwa.* TO 'kali'@'127.0.0.1' IDENTIFIED BY 'kali';  
FLUSH PRIVILEGES;  
EXIT;
```

5. Configurazione e Hardening di PHP ed Apache

Modifica dei parametri del runtime PHP necessari per sbloccare i laboratori di File Inclusion:

```
bash
```

```
# Verificare la versione corrente di PHP installata (es. 8.1)
```

```
cd /etc/php
```

```
ls
```

```
cd /etc/php/8.1/apache2
```

```
# Modificare il file ini con il proprio editor
```

```
nano php.ini
```

Ricercare e configurare i seguenti flag booleani su On

- allow_url_fopen = On

- allow_url_include = On

Riavviare il server web per applicare le modifiche:

```
bash
```

```
service apache2 start
```

6. Finalizzazione del Setup Web:

- Aprire il browser su: <http://127.0.0>

- Verificare lo stato del Setup Check: tutti i moduli richiesti devono mostrare uno stato verde/positivo (ad eccezione del modulo gd o delle chiavi reCAPTCHA che sono opzionali).

- Cliccare sul pulsante "Create / Reset Database" in fondo alla pagina per generare lo schema delle tabelle e popolare l'applicazione.

Fase 3. Vulnerability Management e Testing con Burn Suite

7. Gestione dei Livelli di Sicurezza

- Credenziali di default di DVWA: Username: admin / Password: password

- Navigare sulla scheda DVWA Security nel menu laterale

- Configurazione iniziale: impostare il menu a tendina su “ low “ e cliccare su Submit. In questa modalita il codice sorgente non implementa funzioni di sanitizzazione dell input facilitando le prime tecniche di attacco

8. Analisi del Traffico e Manipolazione della richiesta HTTP:

Obiettivo dell'esercizio e intercettare e manipolare una richiesta di login (Authentication Bypass / Tampering)

1. Intercettazione: Avviare Burp Suite attivare l'opzione Intercept is on nella scheda Proxy

2. Cattura: inviare una richiesta di login dal browser integrato. Burp Suite bloccherà la richiesta POST/DVWA/login.php HTTP/1.1

3. Analisi dei Parametri: Nel corpo della richiesta (Body) si notano le variabili serializzate: username=admin&password=password&Login=Login&user_token= (Token_CRSF)

4. Manipolazione (Tampering): Modificare arbitrariamente i valori inviati ad esempio alterando i campi in
username=ciao&password=ciao

5. Analisi con Repeater: Cliccare con il tasto destro sulla richiesta intercettata Send to Repeater. All'interno della scheda Repeater cliccando su Send l'applicazione risponderà inizialmente con un HTTP/1.1 302 Found (reindirizzamento) verso login. php

6. Verifica dell'Esito: Facendo clic su Follow Redirection viene caricata la risposta HTTP finale (HTTP/1.1 200 OK). Nel codice HTML restituito (analizzabile nel pannello Response) si evince il fallimento dell'autenticazione tramite la stringa <div class="message">Login failed</div>, confermando il corretto funzionamento del meccanismo di autenticazione lato server in presenza di credenziali errate.

Esercizio Facoltativo

Risoluzione Tecnica e Analisi delle Differenze:

Cambiando il livello di sicurezza in Medium e High l'applicazione implementa via software controlli progressivamente più stringenti sulla validazione degli input e sulla gestione delle sessioni . Nel contesto specifico del login e dei test effettuati:

1. Sicurezza “Medium”

- Cosa Cambia: Lato server viene introdotto un controllo basilare (es. un ritardo nell'esecuzione tramite la funzione PHP sleep()) per mitigare attacchi di forza bruta automatizzati veloci).

- Impatto su Burp: Le richieste inviate del Repeater o dall Intruder subiranno una latenza temporale misurabile nella risposta. I parametri di login errati restituiscono comunque un fallimento dell autenticazione.

2. Sicurezza "High"

- Cosa cambia: Viene implementato un controllo stringente sui token anti-CSRF (user_token) . Il token inviato nella richiesta POST deve corrispondere rigidamente a quello generato nell ultima versione della pagina GET precedente. Viene inoltre introdotto un sistema di blocco dell Account (Account Lockout) dopo un numero predefinito di tentativi falliti.

- Impatto su Burp: Un semplice rinvio (Replay Attack) della richiesta tramite Repeater fallirà sistematicamente non solo per le credenziali errate ma anche perché il user_token risulterà obsoleto o già consumato richiedendo l'utilizzo di macro in Burp Suite per estrarre dinamicamente il token valido da ogni risposta precedente.